

Building defenses against malicious bots

hgv

>	!	2024-05-14 14:15:19.545	GET	429	194 B	140 ms	Chrome 123.0...	https://api.bookingsuedtirol.com/widgets/v6/properties/10163/availabilities?from=2024-05-14T14:15:19.545Z
>	!	2024-05-14 14:15:19.545	GET	429	194 B	140 ms	Chrome 123.0...	https://api.bookingsuedtirol.com/widgets/v6/properties/10657/availabilities?from=2024-05-14T14:15:19.545Z
>	!	2024-05-14 14:15:31.966	GET	429	224 B	134 ms	Chrome 123.0...	https://api.bookingsuedtirol.com/widgets/v6/properties/10657/availabilities?from=2024-05-14T14:15:31.966Z
>	!	2024-05-14 14:15:25.709	GET	429	194 B	142 ms	Chrome 123.0...	https://api.bookingsuedtirol.com/widgets/v6/properties/10787/availabilities?from=2024-05-14T14:15:25.709Z
>	!	2024-05-14 14:15:25.709	GET	429	194 B	139 ms	Chrome 123.0...	https://api.bookingsuedtirol.com/widgets/v6/properties/10787/availabilities?from=2024-05-14T14:15:25.709Z
>	!	2024-05-14 14:15:25.709	GET	429	270 B	139 ms	Chrome 123.0...	https://api.bookingsuedtirol.com/widgets/v6/properties/10787/specials?lang=de&sourceId=95
>	!	2024-05-14 14:15:25.709	GET	429	194 B	139 ms	Chrome 123.0...	https://api.bookingsuedtirol.com/widgets/v6/properties/10787/rooms?lang=de&sourceId=95
>	!	2024-05-14 14:15:19.545	GET	429	194 B	142 ms	Chrome 123.0...	https://api.bookingsuedtirol.com/widgets/v6/properties/13303/availabilities?from=2024-05-14T14:15:19.545Z
>	!	2024-05-14 14:15:19.545	GET	429	270 B	140 ms	Chrome 123.0...	https://api.bookingsuedtirol.com/widgets/v6/properties/13303/specials?lang=en&sourceId=95
>	!	2024-05-14 14:15:19.545	GET	429	194 B	141 ms	Chrome 123.0...	https://api.bookingsuedtirol.com/widgets/v6/properties/13303/availabilities?from=2024-05-14T14:15:19.545Z
>	!	2024-05-14 14:15:19.545	GET	429	194 B	140 ms	Chrome 123.0...	https://api.bookingsuedtirol.com/widgets/v6/properties/13303/rooms?lang=en&sourceId=95

The booking platform for South Tyrol

Book accommodations online in an easy and safe way

Holiday destination or accommodation

Arrival – Departure

2 guests – 1 room

Search

Our customers say

Excellent



4.4 out of 5 based on 1,949 reviews

 Trustpilot



WEATHER
8 °C / 24 °C

WHY DO SCRAPERS TARGET OUR PLATFORM?

Booking Südtirol was created as an alternative to international booking portals and charges less service fees from our members.

				
Service fee per stay	15-20%	~14%	9%	0%

Most of the time we can offer the cheapest bookable price.
This makes us an interesting target for scrapers and price comparison services.

HOW TO SCRAPE ALL PRICES FOR A SPECIFIC ACCOMMODATION

Step 1

Fetch availabilities for each month



```
GET /availabilities?adults=2&from=2024-05-01&to=2024-05-30
GET /availabilities?adults=2&from=2024-06-01&to=2024-06-30
GET /availabilities?adults=2&from=2024-07-01&to=2024-07-30
GET /availabilities?adults=2&from=2024-08-01&to=2024-08-30
...
```



```
[
  {
    "date": "2024-07-01",
    "departures": [
      {
        "departure": "2024-07-02",
        "rule": "minimum_stay_not_fulfilled"
      },
      {
        "departure": "2024-07-03",
        "rule": "minimum_stay_not_fulfilled"
      },
      {
        "departure": "2024-07-04",
        "rule": "departure_possible"
      },
      {
        "departure": "2024-07-05",
        "rule": "departure_possible"
      },
      // ...
      {
        "departure": "2024-07-20",
        "rule": "departure_possible"
      }
    ]
  },
  // ... until "2024-07-30"
]
```

Step 2

Retrieve prices for all possible arrival and departure days for the provided guests.



```
// Arrival 2024-07-01
```

```
GET /prices?adults=2&arrival=2024-07-01&departure=2024-07-04
```

```
GET /prices?adults=2&arrival=2024-07-01&departure=2024-07-05
```

```
GET /prices?adults=2&arrival=2024-07-01&departure=2024-07-06
```

```
GET /prices?adults=2&arrival=2024-07-01&departure=2024-07-07
```

```
...
```

```
GET /prices?adults=2&arrival=2024-07-01&departure=2024-07-20
```

```
// Arrival 2024-07-02
```

```
GET /prices?adults=2&arrival=2024-07-02&departure=2024-07-04
```

```
GET /prices?adults=2&arrival=2024-07-02&departure=2024-07-05
```

```
GET /prices?adults=2&arrival=2024-07-02&departure=2024-07-06
```

```
GET /prices?adults=2&arrival=2024-07-02&departure=2024-07-07
```

```
...
```

```
GET /prices?adults=2&arrival=2024-07-02&departure=2024-07-21
```



Why do scrapers target our platform?

CASE STUDY

Adults: 2

Maximum possible stay: 60 days

How many API calls are necessary to retrieve all prices for the next year?

$12 \text{ months} * 30 \text{ arrival days} * 60 \text{ departure days} = 21,600 \text{ API calls}$

What if we multiply this number with all 2.550 bookable accommodations?

$2,550 \text{ accommodations} * 21,600 \text{ API calls} = 55,080,000 \text{ API calls}$

This calculation does not consider other possible occupancies.
Also, prices change constantly.



HOW SCRAPING BOTS AFFECT US

- ◆ Increased load on our web services
- ◆ Higher cloud computing cost
- ◆ Price calculation is an expensive operation and currently a bottleneck
- ◆ They can provoke service degradations
- ◆ Countermeasures can also affect real customers



14. Mai 2024

429 Too many requests

429 Too many requests

Ich hab mehrmals versuchen müssen meine Buchung zu machen und mir war das Problem nur bewusst, weil ich selber Softwareentwickler bin.

von Paddybee 1

Quelle: Einfache Einladung

[+ Tag hinzufügen](#)



Countermeasures

Our bot protection journey



CLOUDFLARE



Good

- ◆ Easy to setup
- ◆ Their service blocks many bad actors, not only scrapers
- ◆ Effective against headless browsers
- ◆ Free captcha alternative ([Turnstile](#))
- ◆ Free CDN

Bad

- ◆ Advanced bot fight mechanisms and API protection only available in enterprise mode (5.000€/month)
- ◆ “Under attack mode” broke our website
- ◆ GDPR issues

We have noticed that the server of your booking widget is located on a Cloudflare server in the USA. This means that when the widget is called up, requests are made to servers in third countries. If users refuse the connection to third countries in the cookie pop-up, we would have to deactivate the booking widget.

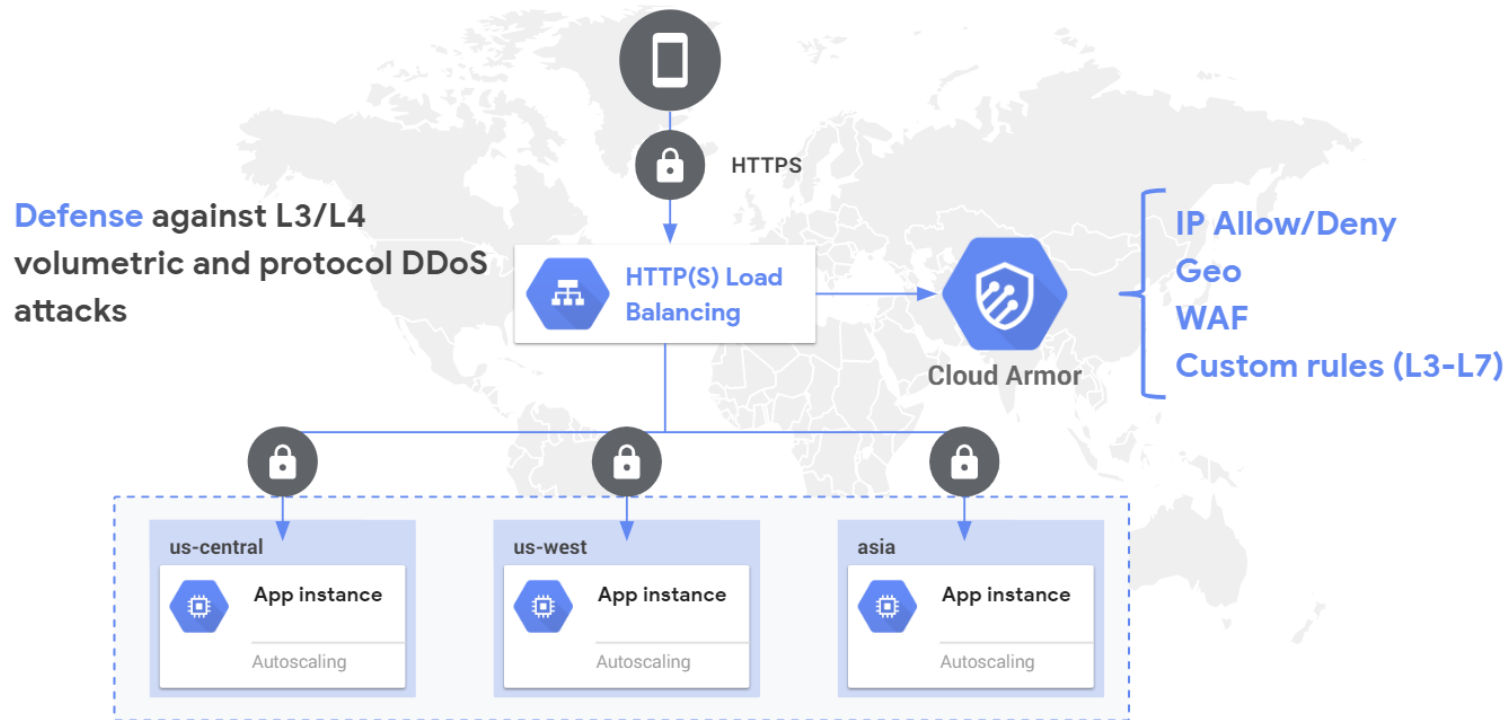
WEB APPLICATION FIREWALL RULES



	Order	Action	Name	CSR ⓘ	Activity last 24hr	Enabled
⋮	1	Block	ASN Block AS Num	-	 79.52k	☒ ⋮
⋮	2	Block	Block Threat Score > 50 Threat Score	-	 6	☒ ⋮
⋮	3	Managed Challenge	Threat Score 3-50 Threat Score	0%	 40	☒ ⋮
⋮	4	Managed Challenge	Challenge countries which are not our main customers Country, Known Bots	2.56%	 6.3k	☒ ⋮

GOOGLE CLOUD

Cloud Armor: DDoS Protection & WAF



IP BLOCKING

Create a blacklist of malicious IPs

Issues

- ◆ Scrapers switch IP addresses constantly
- ◆ Lookup table performance hit
- ◆ False positives blocking legitimate users behind corporate networks



IP deny 192.168.1.2

ASN BLOCKING

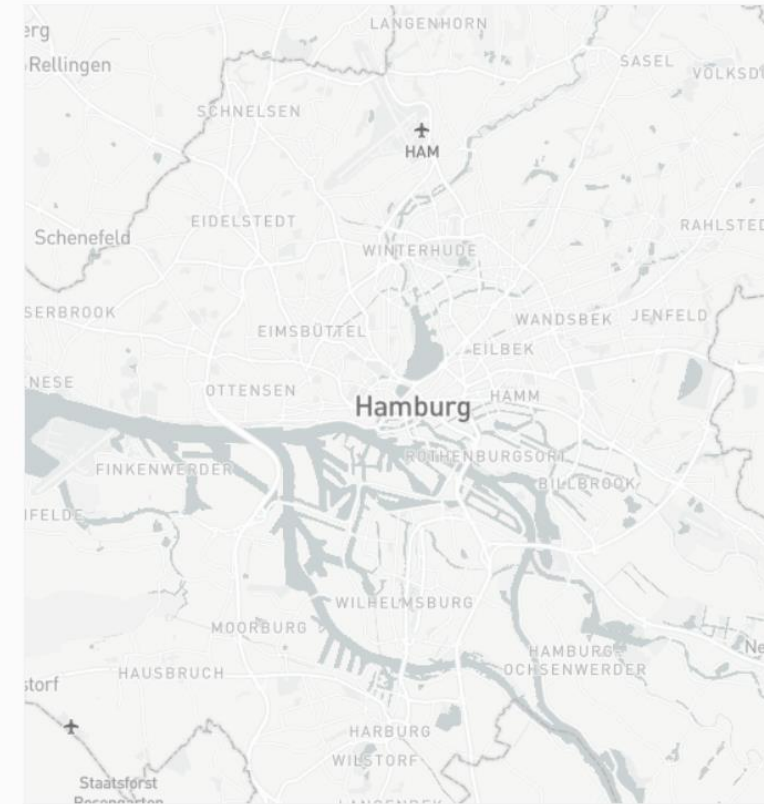
An identifier for a collection of IP networks and routers under the control of one entity.

- ◆ Good for blocking whole ISPs, VPNs or hosting providers
 - Hetzner, OVH, HostRoyale
 - AWS, Azure, GCP
 - NordVPN, Mullvad
- ◆ Use <https://ip-api.com/> to analyse IP addresses

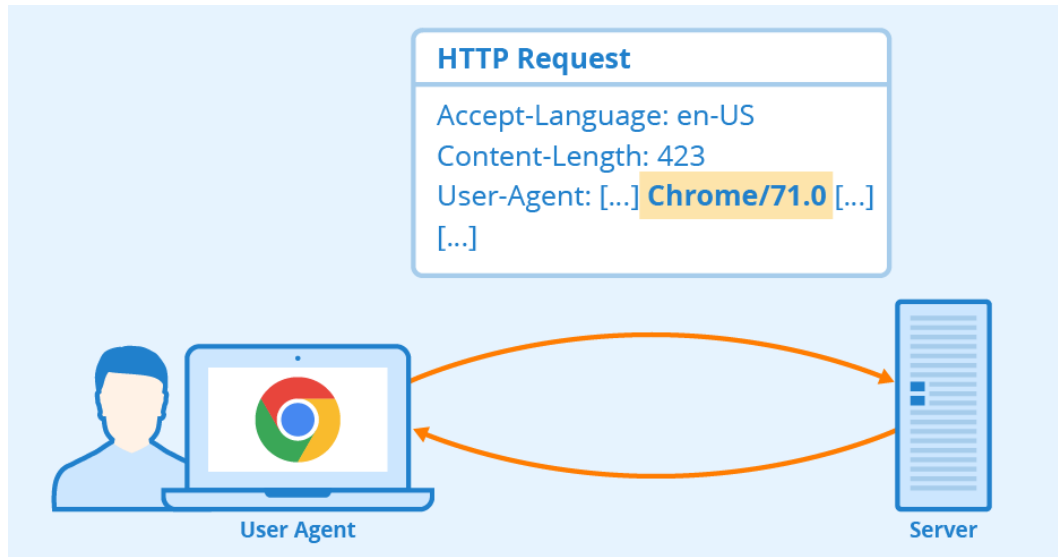
37.44.202.23

SEARCH

```
{
  "query": "37.44.202.23",
  "status": "success",
  "continent": "Europe",
  "continentCode": "EU",
  "country": "Germany",
  "countryCode": "DE",
  "region": "HH",
  "regionName": "Free and Hanseatic City of Hamburg",
  "city": "Hamburg",
  "district": "",
  "zip": "20038",
  "lat": 53.5511,
  "lon": 9.99368,
  "timezone": "Europe/Berlin",
  "offset": 7200,
  "currency": "EUR",
  "isp": "HostRoyale Technologies Pvt Ltd",
  "org": "Ippn Holdings LTD",
  "as": "AS203020 HostRoyale Technologies Pvt Ltd",
  "asname": "HostRoyale",
  "mobile": false,
  "proxy": true,
  "hosting": false
}
```



USER-AGENT BLOCKING



- User-Agent header can be spoofed ⚠
- Rate limiting is better than blocking

>	i	2024-05-21 13:55:14.913	GET	200	2.68 KiB	81 ms	node-fetch
>	i	2024-05-21 13:55:14.908	GET	200	2.4 KiB	90 ms	node-fetch
>	i	2024-05-21 13:55:13.967	GET	200	2.68 KiB	77 ms	node-fetch
>	i	2024-05-21 13:55:13.963	GET	200	2.46 KiB	85 ms	node-fetch
>	i	2024-05-21 13:55:02.932	GET	200	3.39 KiB	82 ms	node-fetch
>	i	2024-05-21 13:55:02.928	GET	200	3.13 KiB	89 ms	node-fetch
>	i	2024-05-21 13:52:06.045	GET	200	3.16 KiB	91 ms	node-fetch
>	i	2024-05-21 13:52:06.040	GET	200	2.85 KiB	100 ms	node-fetch
>	i	2024-05-21 13:50:39.341	GET	200	2.85 KiB	76 ms	node-fetch
>	i	2024-05-21 13:50:39.337	GET	200	2.71 KiB	83 ms	node-fetch
>	i	2024-05-21 13:49:49.760	GET	200	2.85 KiB	86 ms	node-fetch
>	i	2024-05-21 13:49:49.754	GET	200	2.68 KiB	96 ms	node-fetch
>	i	2024-05-21 13:48:39.489	GET	200	4.31 KiB	120 ms	node-fetch
>	i	2024-05-21 13:48:39.485	GET	200	4.15 KiB	127 ms	node-fetch
>	i	2024-05-21 13:47:45.289	GET	200	3.44 KiB	77 ms	node-fetch
>	i	2024-05-21 13:47:45.283	GET	200	3.22 KiB	85 ms	node-fetch
>	i	2024-05-21 13:47:03.884	GET	200	3.18 KiB	87 ms	node-fetch
>	i	2024-05-21 13:47:03.880	GET	200	2.96 KiB	93 ms	node-fetch
>	i	2024-05-21 13:47:03.377	GET	200	3.16 KiB	89 ms	node-fetch
>	i	2024-05-21 13:47:03.373	GET	200	2.85 KiB	96 ms	node-fetch
>	i	2024-05-21 13:46:29.389	GET	200	2.48 KiB	78 ms	node-fetch
>	i	2024-05-21 13:46:29.385	GET	200	2.34 KiB	86 ms	node-fetch
>	i	2024-05-21 13:46:28.240	GET	200	3.18 KiB	82 ms	node-fetch
>	i	2024-05-21 13:46:28.234	GET	200	2.91 KiB	89 ms	node-fetch
>	i	2024-05-21 13:45:44.571	GET	200	2.29 KiB	75 ms	node-fetch

Sophisticated bots

How do they operate?

SCRAPING AS A SERVICE

Web scraping is so lucrative that it has spawned a whole new industry “scraping-as-a-service.” These companies provide bypasses to bot defenses.



Zyte API

Solve Bans and Extract Data

- Highest success rate, fastest response times
- A single AI-powered platform for unblocking and extraction
- Built-in industry compliance standards

Try free

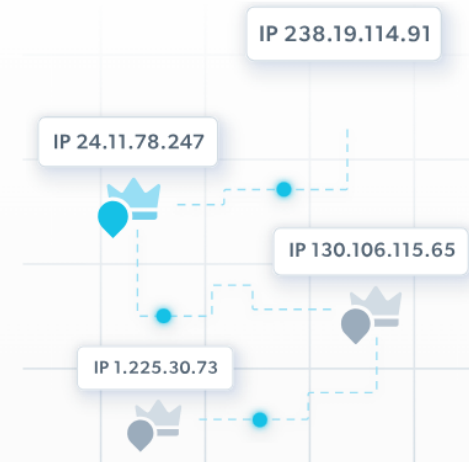
Learn more



Proxies

Premium proxy infrastructure.
100% ethically sourced IPs.

- ✓ Automated session management
- ✓ Target any city in 195 countries
- ✓ Unlimited concurrent sessions



Unlocker

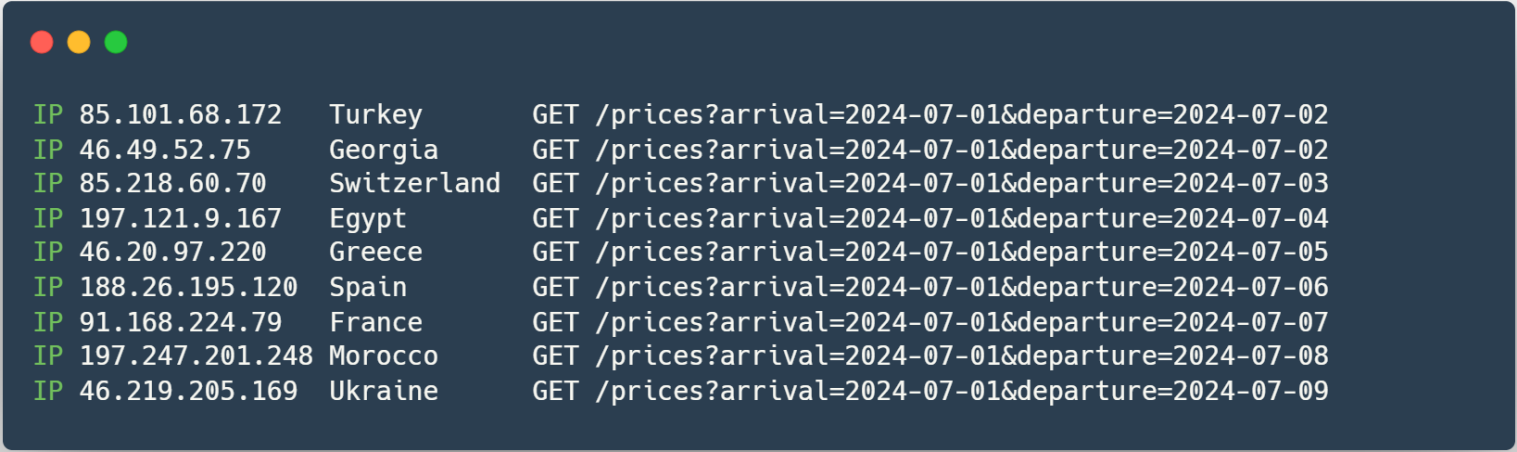
Say goodbye to blocks and
CAPTCHAs with a single API.



Sophisticated bots

RESIDENTIAL PROXIES

- Many proxies run on likely compromised hosts:
 - Router
 - Webcams
 - Media storage devices
 - Phones
- Volunteers can act as proxies and get paid for it
- Free VPN services



```
IP 85.101.68.172 Turkey GET /prices?arrival=2024-07-01&departure=2024-07-02
IP 46.49.52.75 Georgia GET /prices?arrival=2024-07-01&departure=2024-07-02
IP 85.218.60.70 Switzerland GET /prices?arrival=2024-07-01&departure=2024-07-03
IP 197.121.9.167 Egypt GET /prices?arrival=2024-07-01&departure=2024-07-04
IP 46.20.97.220 Greece GET /prices?arrival=2024-07-01&departure=2024-07-05
IP 188.26.195.120 Spain GET /prices?arrival=2024-07-01&departure=2024-07-06
IP 91.168.224.79 France GET /prices?arrival=2024-07-01&departure=2024-07-07
IP 197.247.201.248 Morocco GET /prices?arrival=2024-07-01&departure=2024-07-08
IP 46.219.205.169 Ukraine GET /prices?arrival=2024-07-01&departure=2024-07-09
```

Example of multiple IP addresses crawling prices concurrently from different countries to avoid being blocked

Source: Resident Evil: Understanding Residential IP Proxy as a Dark Service

<https://ieeexplore.ieee.org/document/8835239>

BOT FARMS

These cyber farms have been hugely active in war and politics.



Source: Ukraine Police Busted Bot Farms of Pro-Russia Propaganda; 150,000 SIM Cards Seized

<https://cybersecuritynews.com/ukraine-police-busted-bot-farms/>

Countermeasures

How to protect against these new kind of threats?

CHANGING THE API

Randomly changing URL parameter names and introducing new parameters to confuse the bot developers. Example:

- ◆ Before: </prices?arrival=2024-12-01>
- ◆ After: /prices?arrival=2024-12-01&booking_id=h9y2i5k
- ◆ Bots reveal themselves by using older parameters, so their requests can be blocked through the application logic.
- ◆ Drawback: scrapers can adapt their code to take the API changes into account.

CHANGING THE API: PART TWO

Introducing a hash code URL parameter:

</prices?arrival=2024-12-01&hash=yZbcZl4kfpz...>

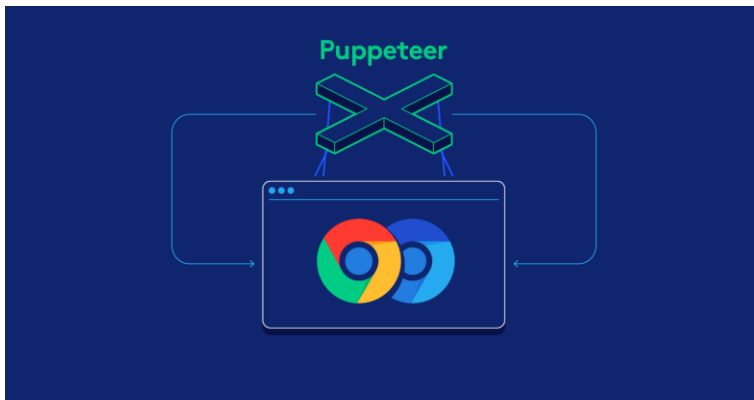
- Browser calculates hash
- Server verifies hash
- If validation fails, block request as it's a bot
- This mechanism worked well for months, until the scrapers became more sophisticated.

```
const createHash = async (
  propertyId: number,
  { adults, arrival, departure, language }: APISearchQueryParams
): Promise<string> => {
  const message = new URLSearchParams({
    adults: String(adults),
    arrival: arrival.toISOString(),
    departure: departure.toISOString(),
    propertyId: String(propertyId + 5372 * 51),
    language: language.toUpperCase(),
    salt: "foo-bar",
  }).toString();

  const hashBuffer = await crypto.subtle.digest(
    "SHA-256",
    new TextEncoder().encode(message)
  );
  return convertBufferToBase64String(hashBuffer);
};
```

HEADLESS BROWSERS

- Scriptable, fully-fledged browser
- Allows to extract data from rendered page
- Can imitate regular user behavior
- More resource-intensive than traditional scraping



```
import puppeteer from 'puppeteer';

(async () => {
  // Launch the browser and open a new blank page
  const browser = await puppeteer.launch();
  const page = await browser.newPage();

  // Navigate the page to a URL
  await page.goto('https://developer.chrome.com/');

  // Set screen size
  await page.setViewport({width: 1080, height: 1024});

  // Type into search box
  await page.type('.devsite-search-field', 'automate beyond recorder');

  // Wait and click on first result
  const searchResultSelector = '.devsite-result-item-link';
  await page.waitForSelector(searchResultSelector);
  await page.click(searchResultSelector);

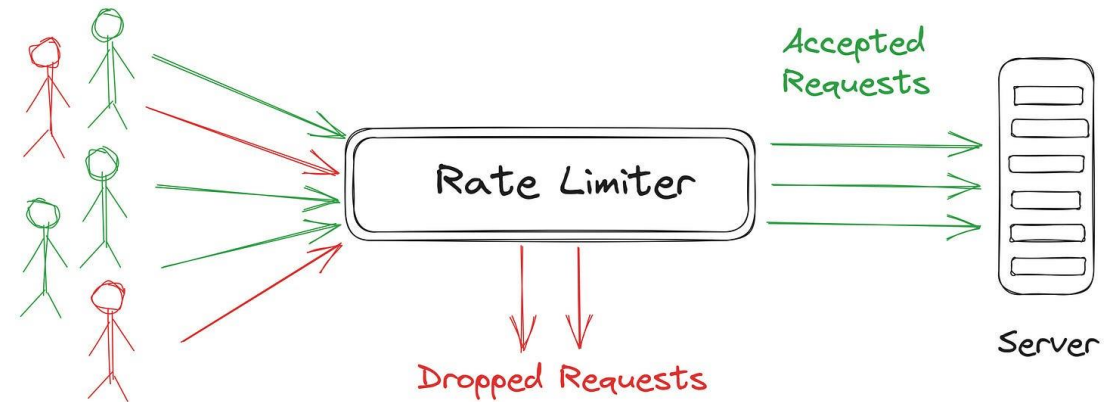
  // Locate the full title with a unique string
  const textSelector = await page.waitForSelector(
    'text/Customize and automate'
  );
  const fullTitle = await textSelector?.evaluate(el => el.textContent);

  // Print the full title
  console.log('The title of this blog post is "%s".', fullTitle);

  await browser.close();
})();
```

RATE LIMITING

- Limit number of requests within a certain period of time, e.g. 1 minute, block exceeding requests
- Possibilities: limit by IP address, User Agent, country or globally for all users



Drawback

- It can also block legitimate users who make a lot of requests



14. Mai 2024

429 Too many requests

429 Too many requests

Ich hab mehrmals versuchen müssen meine Buchung zu machen und mir war das Problem nur bewusst, weil ich selber Softwareentwickler bin.

von [Paddybee](#) 1

Quelle: Einfache Einladung

[+ Tag hinzufügen](#) ⓘ

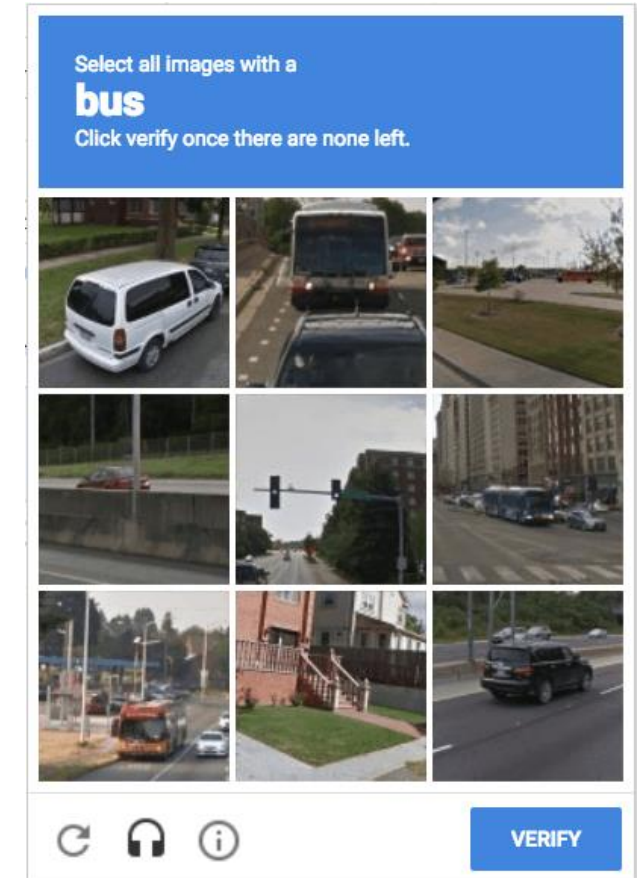
LEGAL ACTION

- ◆ Web scraping is generally legal, but can be illegal in some cases
- ◆ Similarities with denial-of-service attacks
- ◆ Identifying perpetrators can be challenging



OTHER MEASURES

- ◆ Captchas
- ◆ Machine-learning based traffic detection and blocking
- ◆ Serving fake data to scrapers
- ◆ Requiring login
- ◆ Throttling



Takeaways

“By three methods we may learn wisdom: First, by reflection, which is noblest; Second, by imitation, which is easiest; and third by experience, which is the bitterest.” - Confucius



IF YOU ARE A SCRAPING

- ◆ Provide a valid HTTP referrer or User-Agent identifying your application
- ◆ Respect robots.txt
- ◆ Respect terms of service
- ◆ Do not bypass protection mechanisms
- ◆ Use official APIs
 - Scraping is inefficient and bad for the environment
- ◆ Keep request count low to not overload systems



Example Usage Policy: <https://operations.osmfoundation.org/policies/nominatim/>

IF YOU ARE BEING SCRAPED

- ◆ It's impossible to completely block scrapers for public content
 - Don't try to block them all (**protect your mental health**)
- ◆ Use a Web Application Firewall
- ◆ You can make their life harder by
 - constantly changing your API
 - rate-limiting by IP address, User-Agent, referrer and countries
 - blocking ASNs from known VPNs and hosting services
- ◆ Leverage caching
- ◆ Add legal note about scraping in your general terms and conditions page
- ◆ Monitoring and alerting is important



Thank you
for your attention.

